# Wild West Hackin' Fest Toolshed Talk: Locksmith

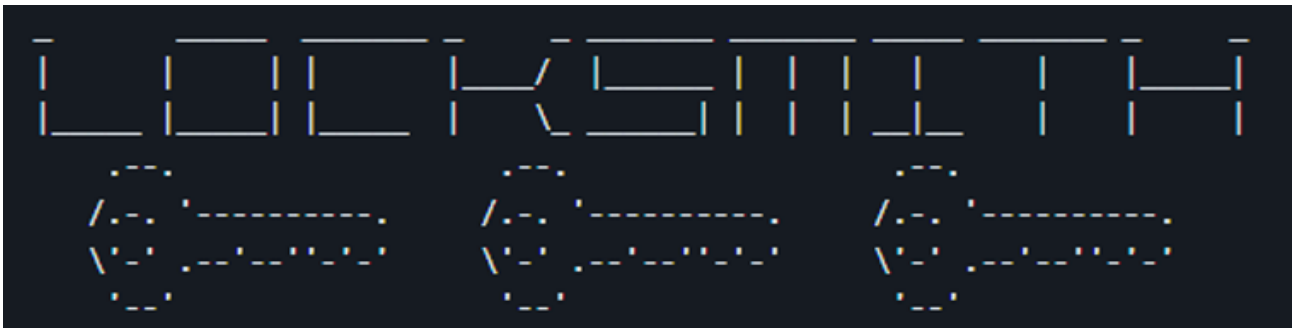
trimarcsecurity.com/hub-post/wild-west-hackin-fest-toolshed-talk-locksmith

Jake Hildreth October 28, 2022

Updated: Dec 13, 2024

## Introducing: LockSmith

Good afternoon, Wild West Hackin' Fest. My name is Jake Hildreth. Thank you for choosing to attend my presentation about Locksmith, a tiny tool for fixing common and dangerous Issues in Active Directory Certificate Services. You can download my slides for this talk by clicking that little clicky thing below.



## Who am I and why should you listen to me?

I've been in the technology for over 20 years. Started out in Help Desk for the @Home cable modem conglomerate, then spent a couple years at a small-business focused MSSP (before that was a popular term). There I had a great mentor who taught me that security is mostly synonymous with operational excellence. (No, it wasn't Swifty.)

After that, I then spent 16 years working in local government as a "Network Administrator" where I planned to retire. I spent the last half of my tenure undoing all the stuff my predecessors had done to Active Directory which rekindled my interest in security.

In May 2021, I saw a tweet by Sean Metcalf that read:

*"If you have been managing Active Directory and/or Azure AD/Office 365 in an operations role and are trying to figure out how to shift to a role in infosec/cybersecurity, my DMs are open!"*

I poured my heart out to him about the frustrations I had with working for a local government in a chronically underfunded IT department. After a few conversations of ever-

increasing seriousness, I joined Trimarc as part of the Identity Security team focusing on the on-prem side of the Microsoft Identity stack.

I define myself as a husband first, a father second, and a Blue Teamer for life (though the red arts are kinda fun too). Because you chose to come to this talk, I am going to guess you know what AD CS is. But here's a quick primer just in case you are not aware.

## Microsoft's version of Public Key Infrastructure.

AD CS has been part of Active Directory since its initial release, but before 2008, it was just called Certificate Services. It can be setup in about 10 minutes by the traditional "Next Next Next Next, etc" method. It's commonly used for secure communication between domain controllers, File Encryption, Secure Email, and encrypted LDAP, but we won't really be talking about any of those uses right now.

Today we will be concentrating on common issues with certificate-based authentication with a little discussion about infrastructure. Why is it so easy to screw up? Well, it uses Active Directory as its source of truth and, well, I'll leave it at that.

## Pre-history

CPO: SpecterOps collected all the info spread across blogs and internet archives and other dark corners of the internet and condensed it into a breezy 143 beach read called "Certified Pre-Owned". And thus the modern world of AD CS began. Shortly thereafter, I started working at Trimarc and almost immediately volunteered to start building AD CS guidance into our AD Assessment service.

Then in April of 2022, Mandiant revealed that they identified APT29 using the techniques described in Certified Pre-Owned to escalate to domain admins and maintain persistence in multiple incidents. All through 2022, multiple pentesting companies have privately mentioned to Trimarc about the prevalence of AD CS vulnerabilities in environments they've tested. They're so common that it's almost too easy.

So, what types of vulnerabilities are we talking about exactly? The most common issue by far is the lack of auditing. While this isn't a vulnerability that would lead to privilege escalation or domain compromise, it makes tracking down AD CS issues incredibly difficult.

In the nearly 20 environments we've looked at in Trimarc, exactly zero have had auditing properly enabled. This is because of three reasons:

1. AD CS auditing is completely disabled by default.
2. Auditing must be enabled on each individual Certificate Authority. If you miss one, that's the one attackers will use.
3. Full auditing requires at least two additional GPO settings to be properly configured.

Next most common is overly-permissive ACLs. Since every AD CS object is a securable object, it's incredibly easy to give low-privileged users the privileges needed to modify templates or other objects to either escalate privileges or at the very least maintain persistence. The most common "dangerous" vulnerabilities we've seen during assessments are templates with dangerous configurations.

There are two primary types of dangerous templates & each is dangerous in its own *fun* way.

1. The more common of the two types of dangerous templates allows anyone to **request a certificate in the name of another security principal without any approval process**. And when I say "any security principal", I mean it. Domain Admins, a Domain Controller, whatever. Not only does this allow for authentication as that principal, but it also allows for persistence because the dangerous certificates are not revoked when a user's password is changed!

2. The other type of dangerous template **allows anyone to request a SubCA certificate**. This type of certificate allows an attacker to create new certificates that are inherently trusted by Active Directory!

The last bullet point on this list *was* incredibly dangerous though the danger has, somewhat recently, been diminished. Basically, if a certain flag is can set on any Certificate Authority in your environment, almost all templates in AD CS become vulnerable to escalation! Thankfully, this danger has been mitigated slightly by some updates released in May of 2022.

So, with all these incredibly common vulnerabilities in mind, I decided to do something about it!

## Enter Locksmith.

Here's what it can do.

- Scans your AD CS environment.
- Finds vulnerable configurations & reports on them.
- (PSPKIAudit, Certify, Certipy all already do this stuff.)

- Remediates.

Future state wish list:

- Text-Based User Interface – Passing Parameters is fine for Locksmith's current intended audience, but it will need to be more user friendly soon.
- Improved Error Handling – Since this grew out of an internal tool that only I can fully wield, it needs some UX love.
- Multi-Forest Support – In modern enterprise environments, there are trusts on trusts on trusts, and it would be nice to not have to run this thing multiple times.
- Verifies Auditing GPOs exist, Alert if not. – Generic warnings result in wasted time and effort. My goal with Locksmith is to reduce wasted time and effort, so let's only warn if the required auditing GPOs do not exist.
- Improved Remediation of overly-permissive ACL issues.
- Additional methods to remediate dangerous templates – Forcing Manager Approval seems to be the least impactful, but other options for this fix include.
- Check for elevation before attempting to fix anything.

## Huge Thanks to:


- Black Hills Cinematic Universe, Antisyphon Training, Wild West Hackin' Fest, and all of the things.
- Special Thanks to John Strand whose PWYC classes gave me the confidence to leave a verrrry stable position in local government for the wild world of the private sector.
- Sean Metcalf and the rest of the Trimarc crew on the ground out there in Deadwood: Darryl, Jim, and Danny.


### Contact Info


**Discord**: dotdotdotHorse#9755

**Email**: Too personal.

**Phone**: What is this? 1940? Absolutely not.